

# Executive Summary — Security & Compliance Posture

GRC Management System — Princess Sumaya University for Technology

Generated: 2026-04-29 08:17 • AI-Assisted Narrative (claude-sonnet)

ⓘ This narrative was generated by AI based on live GRC system data. Figures are drawn directly from the database at time of generation.

## 1. EXECUTIVE NARRATIVE

Our GRC assessment as of April 29, 2026 reveals a significant disparity between perceived and actual security posture, with self-assessed compliance at 68.3% while evidence-weighted compliance stands at only 36.3%. This 32-percentage-point gap indicates substantial overconfidence in our control effectiveness and highlights the critical need for robust evidence collection and validation processes. Of our 443 total controls, only 102 are fully compliant, while 210 remain unassessed and 29 are non-compliant, creating considerable regulatory and operational exposure across multiple frameworks including ISO 27001 and NIST 800-53. The risk landscape presents immediate concerns with all 169 identified risks remaining open, including 61 critical and 105 high-severity items. The top five critical risks expose fundamental security gaps in user authentication, malware protection, and hardcoded credentials that could lead to unauthorized access and system compromise. With only 2 pieces of evidence submitted and both pending approval, our ability to demonstrate compliance to auditors and regulators is severely compromised. Immediate action is required to address these critical vulnerabilities, establish proper evidence management processes, and implement a systematic approach to risk mitigation before these exposures materialize into security incidents or regulatory sanctions.

## 2. COMPLIANCE OVERVIEW



| STATUS              | COUNT | SHARE OF ACTIVE CONTROLS   |
|---------------------|-------|----------------------------|
| Compliant           | 102   | <div><div></div></div> 23% |
| Partially Compliant | 68    | <div><div></div></div> 15% |
| Non-Compliant       | 29    | <div><div></div></div> 7%  |
| Not Set             | 210   | <div><div></div></div> 47% |
| Not Applicable      | 34    | <div><div></div></div> 8%  |

## 3. RISK SUMMARY

|                |             |             |          |                      |             |
|----------------|-------------|-------------|----------|----------------------|-------------|
| 61<br>CRITICAL | 105<br>HIGH | 3<br>MEDIUM | 0<br>LOW | 169<br>OPEN / ACTIVE | 0<br>CLOSED |
|----------------|-------------|-------------|----------|----------------------|-------------|

| # | RISK TITLE                                                           | CATEGORY                          | SCORE | LEVEL    | STATUS |
|---|----------------------------------------------------------------------|-----------------------------------|-------|----------|--------|
| 1 | Absence of User Identification and Authentication Controls           | Identification and Authentication | 25    | Critical | Open   |
| 2 | No Malware Protection Exposes Organization to Cyber Threats          | Technological Controls            | 20    | Critical | Open   |
| 3 | [Security Audit] Hardcoded API Keys and Secret Keys                  | Technical                         | 20    | Critical | Open   |
| 4 | [Security Audit] Hardcoded Database Password in Configuration        | Technical                         | 20    | Critical | Open   |
| 5 | Undocumented Unauthenticated Actions Create Unauthorized Access Risk | Access Control                    | 16    | Critical | Open   |

4. FRAMEWORK COMPLIANCE BREAKDOWN

| Framework  | Full Name          | Self-Assessed | Evidence Score | Progress               | Assessments |
|------------|--------------------|---------------|----------------|------------------------|-------------|
| ISO27001   | ISO/IEC 27001:2022 | 72.5%         | 36.3%          | <div><div></div></div> | 3           |
| NIST800-53 | NIST SP 800-53     | 65.5%         | Pending        | <div><div></div></div> | 1           |
| OWASP-ASVS | OWASP ASVS         | No data       | Pending        | <div><div></div></div> | 0           |
| CIS        | CIS Benchmarks     | No data       | Pending        | <div><div></div></div> | 0           |

5. EVIDENCE HEALTH

|             |          |                |          |               |
|-------------|----------|----------------|----------|---------------|
| 2           | 0        | 2              | 0        | 0%            |
| TOTAL FILES | APPROVED | PENDING REVIEW | REJECTED | APPROVAL RATE |

Top non-compliant control categories:

| Category                                  | Non-Compliant Controls |
|-------------------------------------------|------------------------|
| Technological Controls                    | 5                      |
| Organisational Controls                   | 4                      |
| System and Communications Protection      | 3                      |
| Audit and Accountability                  | 2                      |
| Assessment, Authorisation, and Monitoring | 2                      |

6. PRIORITY RECOMMENDATIONS

- 1

Immediately implement user identification and authentication controls for all system access points.
- 2

Deploy comprehensive malware protection across all organizational endpoints and network infrastructure.
- 3

Conduct emergency security audit to identify and remediate all hardcoded credentials.
- 4

Establish formal evidence collection process with assigned ownership and approval workflows.
- 5

Prioritize assessment of 210 unset controls to achieve baseline compliance posture.

Recommendations generated by AI based on current GRC system data. Management should validate before action.